

AMENAZAS PERSISTENTES AVANZADAS.



ANÁLISIS DE GRUPOS APT. OBJETIVO: EUROPA

Resumen: Abordaremos a Europa como objetivo de nuestro análisis de grupos APT, intentaremos vislumbrar si realmente hay tan pocos grupos como parece o en cambio puede que haya algo detrás de esa mínima presencia europea de grupos APT.

Etiquetas: Ciberseguridad, ciberdelincuencia, APT, Amenaza, Europa
Europa cuenta con 50 países, incluyendo Rusia, Kazajistán y Turquía aunque sean países transcontinentales. Por la cantidad de países, es probable que de entre tantos, a algunos de ellos se les hayan atribuido ataques de grupos APT. Esta vez, dejaremos a Rusia fuera del análisis, dado que lo analizamos en un artículo anterior. En este análisis se incluye a Reino Unido, que aunque con el Brexit salió de la Unión Europea, estamos hablando del continente europeo, no de las alianzas como la UE (que cuenta con 27 países miembro).

PAÍSES

En los registros de ThaiCert, Europa cuenta con 14 atribuciones posibles en 8 países distintos que son:

- Italia
- Francia
- Reino Unido
- Bielorrusia
- Ucrania
- Rumania
- Kazajistán
- Turquía

Observando el mapa anterior, podemos detectar dos zonas diferenciadas, dicha zona se divide en países limítrofes o cercanos a Rusia frente a tres potencias europeas como son Reino Unido, Francia e Italia, miembros del G-4 junto con Alemania.

Teniendo en cuenta esta situación, es posible pensar que Rusia puede que esté compartiendo parte de su conocimiento con los países cercanos, aunque es bastante cuestionable dadas las relaciones que tiene con algunos países como Ucrania y de si parte del G-4 (al que llamaremos Grupo G-3) está colaborando entre sí para generar su propia inteligencia APT para hacer frente a las amenazas de los demás países.

GRUPO “G-3”

REINO UNIDO

Este es un caso controversial por que las acciones con atribución a Reino Unido apuntan al GCHQ (Government Communications Headquarters), uno de sus servicios de inteligencia, con lo que sus acciones estarían respaldadas por el estado, dichas acciones (SIGINT) se remontarían a su fecha de creación, 1 Noviembre de 1919, un año después del final de la I Guerra Mundial, con lo que puede ser uno de los grupos APT conocidos más antiguo hasta la fecha.

Edward Snowden reveló a The Guardian que el GCHQ espió a los políticos extranjeros que visitaban la Cumbre de Londres del G-20 de 2009 escuchando llamadas telefónicas, correos electrónicos y monitorizando sus ordenadores, además este espionaje se mantuvo tiempo después del evento por medio de keyloggers que se habían instalado durante el mismo.

En 2014, The Intercept reveló en un artículo que GCHQ se introdujo entre 2010 y 2011 en las redes de Belgacom, la empresa de telecomunicaciones más grande de Bélgica. A la vez que la noticia, The Intercept reveló el 13 de Diciembre de 2014 diversos documentos clasificados sobre la operación relativa a Belgacom.

Con estas declaraciones se puede afirmar que el objetivo principal de este grupo APT sería el espionaje y robo de información a otros países, centrándose en el G-20 y extrapolando a la Unión Europea, al incluir a Bélgica entre sus objetivos.

Según los datos de ThaiCert, este grupo APT utilizaba el malware Regin, perteneciente a Equation Group, grupo asociado a TAO (Tailored Access Operations) centro de recopilación de información relacionada con ciber guerra de la NSA (National Security Agency) de Estados Unidos, esta relación nos deja una pregunta en el aire: ¿Cómo consiguió Regin el GCHQ?

La respuesta a esta pregunta nos deja aún más preguntas, ¿Podría ser que estas dos agencias estuvieran colaborando entre sí? ¿Cabe la posibilidad de que se estuviera haciendo un ataque de falsa bandera? ¿Es posible que TAO infectara a GCHQ y estos últimos pudieran haber registrado muestras y hecho un proceso de ingeniería inversa para poder usarlo a su favor? Solo se puede especular al respecto.

FRANCIA

El grupo APT llamado “Animal Farm” o “Snowglobe” está adscrito a la inteligencia francesa según atribuciones, aunque no se define ningún servicio de inteligencia concreto. Este grupo APT ha usado en sus acciones diversas herramientas como Babar,

Casper, Dino, EvilBunny, Tafacalou, Nbot y Chocopop, todas de creación propia, así que no se les puede asociar con otro grupo ya existente.

Se le atribuye su procedencia francesa dado que en el código o nombre de algunas de las herramientas hay referencias francesas como “Babar” que es un popular programa infantil emitido entre 1989 y 1991 con reposiciones hasta 2002 o el juego de caracteres de la programación del malware (locale) es “fr_FR”, indicativo que hace referencia al juego de caracteres del idioma francés de Francia.

Esto último es importante, porque si indagamos descubrimos que “Babar” se ha emitido en 30 idiomas a lo largo de 150 países, de esos 150 países, si nos fijamos en los países de producción aparecen Canadá y Francia. ¿En Canadá no se usa el francés? Sí, pero su “locale” es “fr_CA”, no “fr_FR” por lo que en un principio está fuera del foco dejando a Francia como culpable.

¿Sería posible para alguien canadiense, cambiar el juego de caracteres para usar el francés de Francia y poder así simular un origen galo? Sin duda. Si fuera esa la situación nos encontraríamos ante una atribución con ataques de falsa bandera simulando ser Francia cuando en realidad no es así.

Entre los sectores afectados por este grupo APT se encuentra Defensa y Gobierno, y entre los objetivos se encuentran Estados Unidos, Reino Unido, China, Alemania, Ucrania, Rusia, Turquía, España, Argelia y Marruecos.

ITALIA

Italia se volvió famosa en 2015 después de que una persona bajo el alias de “PhineasFisher” dejase al descubierto 400GB de datos internos de la empresa HackingTeam con sede en Milán. Dichos datos incluían código fuente, correos electrónicos y lista de clientes.

Esta empresa comercializaba un software llamado RCS (Remote Control System) a agencias y gobiernos de todo el mundo.

Como su nombre indicaba, era un software de control remoto, con diversas capacidades como extracción de archivos de un dispositivo, interceptación de correos electrónicos y sistemas de mensajería instantánea y activación remota de la cámara y micrófono. Capacidades propias de un APT.

Después de la filtración de sus datos en 2015, parece ser que la empresa se recuperó y siguió su actividad, al menos hasta 2018, en el que ESET descubrió un RCS evolucionado y con un nuevo certificado digital válido.

Entre la lista de clientes de HackingTeam podemos destacar la Policía de Italia, el FBI, CIA y la DEA y Departamento de Defensa de Estados Unidos, Anticorrupción Nacional de Rumanía, KVANT de Rusia, la división 5163 de la armada de Corea del Sur (Servicio de Inteligencia Surcoreano) y el Centro Nacional de Inteligencia de España... Encontramos algo de presencia en Latinoamérica con la aparición de Colombia, México, Chile y Ecuador en la lista.

Poco después del ataque, supuestamente PhineasFisher colgó en Pastebin una explicación de cómo logró vulnerar la seguridad de la empresa HackingTeam en español. A lo que David Vincenzetti, CEO de HackingTeam respondió según registra este artículo de ESET.

Según lo investigado, esta empresa-grupo APT no estaba patrocinada por el estado, o al menos de forma directa, dado que tenía a varias organizaciones de diversos estados como clientes. En un artículo de Gizmodo se explica el funcionamiento de esta empresa. Tampoco podríamos definir objetivos, ya que en este caso estaríamos hablando de clientes de una empresa y no de víctimas de ataques de un grupo APT.

BLOQUE “RUSO”

BIELORRUSIA

Según los datos de ThaiCert, en 2011 se descubrió una botnet a la que se le dio el nombre de Andrómeda operada por un supuesto grupo APT llamado Andromeda Spider atribuido a Bielorrusia.

Esta botnet fue activa hasta 2017, año en el que se detuvo a su operador y sus acciones pararon.

En Avast se analizó en detalle esta botnet y se produjo un informe sobre su funcionamiento.

Se ha detectado uso de esta botnet por parte de APT36, atribuido a Pakistán.

El fin de esta botnet era obtener beneficio financiero marcando como objetivo a cualquier país del mundo.

UCRANIA

En Ucrania se detectó un grupo APT en 2013 y dos operaciones en 2008 y 2018. Al grupo APT detectado se le llamó Carbanak / Anunak y según noticias parece ser que está activo actualmente (2021) dados algunos ataques de Ransomware. La detención de su líder en Alicante (España) en Marzo de 2018 no impidió que el grupo APT siguiera con sus acciones. Poco después, en Agosto de 2018 se detuvo a la banda. Probablemente solo fuera parte de ella, pues a día de hoy el malware sigue en funcionamiento.

Dicho grupo usaba bastantes herramientas para efectuar sus golpes, enfocados en bancos e instituciones financieras, pero es el malware “Carbanak” del que toma el nombre. Malware utilizado también por el grupo APT FIN7/APT32 atribuido a Rusia. El fin de este malware era obtener beneficio financiero y podríamos marcar Estados Unidos, el continente europeo y asiático como sus objetivos dada su lista de países atacados en la que se incluye a Estados Unidos, Reino Unido, España, Ucrania, Alemania, Francia, Hong Kong y Luxemburgo entre otros.

Las operaciones “Groundbait” en 2008 (ESET) y “Poison Needles” en 2018 (Qihoo 360) fueron ataques con atribución Ucraniana pero de los que no se han descubierto

actores, podrían haber sido efectuadas por Carbanak, por otro grupo o por otros dos grupos APT distintos.

“Groundbait” tenía como objetivo a la propia Ucrania y su finalidad era espiar a políticos y reporteros, mientras que “Poison Needles” se centraba en el sector salud y en Rusia.

RUMANIA

Atribuido a Rumanía encontramos a un grupo curioso por sus fines. Se trata del grupo APT Wolf Spider/FIN4. Su finalidad ya no es obtener sólo beneficio económico, sino obtener ventaja en el comercio de acciones por medio de intrusiones a los sistemas de las empresas para obtener información privilegiada que les permita influir en la subida o bajada de los precios de las acciones de dichas empresas como correos electrónicos de ejecutivos, asesores jurídicos y en definitiva de cualquier cargo que maneje información confidencial de relativo interés para el mercado.

KAZAJISTÁN

En Kazajistán tenemos atribuciones de un grupo APT llamado Fxmsp y de una operación llamada “Manul”.

Fxmsp/ATK 134/TAG-CR17 fue un grupo APT activo desde 2016 y principalmente en sus tácticas usa herramientas de acceso remoto para obtener beneficio financiero. En Julio de 2020 las autoridades estadounidenses acusaron a Andrey Turchin, residente en Kazajistán de cinco cargos de delito grave en relación con fraude. Turchin pasó por una serie de alias, incluyendo “fxmsp”, según el Departamento de Justicia. Inicialmente fue acusado en Diciembre de 2018 pero se mantuvo en secreto hasta Julio de 2020 cuando Cyberscoop se hace eco de la situación informando de sus actividades.

La operación “Manul” se cree que es obra del gobierno de Kazajistán tomando acciones contra periodistas, disidentes que viven en Europa, sus familiares, socios conocidos y sus abogados, ya que muchos de los objetivos están implicados en litigios con el gobierno de Kazajistán en tribunales europeos y estadounidenses cuyo contenido van desde intentos del gobierno de Kazajistán de desenmascarar a los administradores que están detrás de un sitio web anónimo que publica filtraciones que denuncian la corrupción del gobierno (Kazaword) hasta acusaciones de secuestro.

Dicho espionaje se realizaba por medio de ataques de phishing y parecen ser obra de una empresa de seguridad india llamada Appin Security Group, ya que según análisis se han encontrado relaciones entre esta operación y dicha empresa.

TURQUÍA

Turquía tiene atribuidos 4 grupos APT, a contar, “Promethium” o “StrongPity” por la herramienta que usaban, “Neodymium”, “Sea Turtle” y “Vendetta” o “TA2719”. Promethium es un grupo APT que lleva activo al menos desde 2012. Este grupo llevó a cabo una campaña en mayo de 2016 en la propia Turquía, por lo que podemos inferir que no se trata de un grupo APT patrocinado por el estado. Promethium tiene similitud con otro grupo APT llamado Neodymium debido a la coincidencia de las víctimas y las características de la campaña.

La primera aparición de Neodymium fue en 2016, grupo APT conocido por usar el malware “Wingbird”. Debido a un análisis de Wingbird, se infirió que éste malware era una variante de “FinFisher”, un malware de vigilancia de grado gubernamental. Este malware también fue usado por otro grupo llamado BlackOasis, atribuido a Oriente Medio, aunque las técnicas y procedimientos usados por este grupo sean similares a los usados por Neodymium, no existen evidencias de que sea un alias de éste.

Sea Turtle tiene como objetivo entidades públicas y privadas, incluidas organizaciones de seguridad nacional, ubicadas principalmente en Oriente Medio y el Norte de África, aunque también se han descubierto indicios en Estados Unidos. La investigación de Cisco Talos reveló que al menos 40 organizaciones diferentes en 13 países diferentes fueron comprometidas durante la campaña efectuada por Sea Turtle en 2019. Talos evaluó la situación y sostuvo con un alto índice de confianza que esta actividad estaba siendo llevada a cabo por un actor avanzado, patrocinado por el Estado, que buscaba obtener acceso persistente a redes y a sistemas sensibles usando el malware Drupalgeddon.

Vendetta, apodado por Qihoo 360 o TA2719, por Proofpoint, es un grupo APT de reciente aparición (2020) que usaba herramientas de acceso remoto (RAT) junto con tácticas de phishing para atacar a sus víctimas. Quiho 360 detectó ataques de phishing con motivos policiales avisando de una supuesta investigación por contagio de COVID-19, mientras que los ataques detectados por Proofpoint sostenían ataques de phishing basados en suplantación de bancos locales, fuerzas de seguridad y servicios de envío. Entre los países afectados de este ataque se encuentran Estados Unidos, Italia y España. Todos los grupos APT con atribución turca tienen como finalidad el espionaje y la adquisición de información.

¿ESPAÑA TIENE ALGÚN PAPEL EN LOS GRUPOS APT?

De momento ninguna firma de seguridad ha atribuido a España el origen de ningún grupo APT. Sin embargo, hay que mentar a un malware concerniente a España. El malware “Careto” que Kaspersky descubrió en Febrero de 2014, afirmó que este malware se encontraba activo desde 2007 y éste se componía de dos variantes “SGH” y “Careto”, con la peculiaridad de ser altamente modulares, capacidad que facilitaba ataques a medida y posteriores actualizaciones. Se le atribuyó origen español, entre otras cosas, al descubrir que su clave de cifrado RC4 en la comunicación con los servidores de comando y control (C&C, C2C) era “Caguen la Mar”, derivado de “cagüen la mar” expresión coloquial en España. Un análisis más exhaustivo lo encontramos en este artículo. Aunque algún artículo lo ha asociado a la inteligencia española y otro asegura que su forma de actuar no se encuentra en malware asociado al cibercrimen, entre los objetivos de este malware se encuentra la propia España, algo extraño de tratarse de un malware apoyado por el estado. ¿Podrían tratarse de pruebas los ataques dirigidos a España o en cambio nos encontramos ante un ataque de falsa bandera?

Por otro lado, encontramos en la lista de clientes de HackingTeam al Centro Nacional de Inteligencia español. Según este artículo, adquirieron licencias y mantenimiento del software RCS desarrollado por HackingTeam. Esto no es algo malo, al fin y al cabo,

estamos hablando de un organismo de inteligencia perteneciente a un estado, es normal que estos organismos adquieran servicios y productos de este tipo, para facilitar su trabajo, aumentar su conocimiento o incluso mejorar sus propias herramientas.

Por último, nos queda analizar España como objetivos de ataques de grupos APT. En este punto nos encontramos con que España parece ser un país estratégico importante en las acciones de estos grupos ya que ha sido objetivo de ataques atribuidos a Rusia, China, Ucrania, Corea del Norte, Francia, Turquía, Irán, India, Pakistán, algunos desconocidos y el propio país si tenemos en cuenta la posible atribución de “Careto”.

CONCLUSIONES

Aunque en un principio teníamos la impresión de que Europa flaqueaba en movimientos de grupos APT en comparación con Rusia y Asia, se ha demostrado que probablemente esto no es así dado la cantidad de grupos y operaciones encontradas.

Se puede inferir que es poco probable que entre los integrantes del grupo “G-3” compartan información sobre sus artefactos y operaciones, debido a que nos encontramos que la mayoría de las veces son objetivos entre sí.

Por consiguiente es poco probable que Rusia comparta información sobre sus acciones con los países cercanos, además de por su forma de actuar y pensar que analizamos en otro artículo, es debido a que ha sido objetivo de China, Turquía, Ucrania y hasta de grupos en las que la propia atribución es Rusa.

Por último, nos queda señalar el hecho de que España parece ser un objetivo estratégico para las campañas de malware dadas las evidencias de ataques recibidos.

Iván Carlo Alcañiz Bautista

BIBLIOGRAFÍA

- Noticia Edward Snowden – The Guardian GHQ G-20: <https://www.theguardian.com/uk/2013/jun/16/gchq-intercepted-communications-g20-summits>
- Documentos GHQ-Belgacom:
 - <https://theintercept.com/document/2014/12/13/gchq-automated-noc-detection-2011/>
 - <https://theintercept.com/document/2014/12/13/gchq-mobile-networks-noc-world/>
 - <https://theintercept.com/document/2014/12/13/gchq-making-network-sense-encryption-problem-2011/>
 - <https://theintercept.com/document/2014/12/13/gchq-stargate-cne-requirements/>
 - <https://theintercept.com/document/2014/12/13/gchq-nac-review-october-december-2011/>
 - <https://theintercept.com/document/2014/12/13/gchq-nac-business-review-january-march-2011/>
 - <https://theintercept.com/document/2014/12/13/gchq-nac-review-april-june-2011/>
 - <https://theintercept.com/document/2014/12/13/gchq-nac-review-july-september-2011/>
 - <https://theintercept.com/document/2014/12/13/gchq-nac-review-january-march-2012/>

- Tabla de “Locales”: https://docs.moodle.org/dev/Table_of_locales
- Disección del malware
“Babar”: <https://www.gdatasoftware.com/blog/2015/02/24270-babar-espionage-software-finally-found-and-put-under-the-microscope>
- Análisis de herramientas de “Animal Farm”: <https://resources.infosecinstitute.com/topic/animal-farm-apt-and-the-shadow-of-france-intelligence/>
- Disección del malware
“Dino”: <https://www.welivesecurity.com/2015/06/30/dino-spying-malware-analyzed/>
- Lista de clientes de HackingTeam: https://en.wikipedia.org/wiki/Hacking_Team#Customer_list
- Explicación PhineasFisher sobre seguridad de HackingTeam: <https://web.archive.org/web/20161130181609/http://pastebin.com/GPSHF04A>
- Funcionamiento de HackingTeam según Gizmodo: <https://es.gizmodo.com/hacking-team-asi-funciona-la-empresa-hackeada-contrata-1715945205>
- Disección de la botnet “Andrómeda”: <https://blog.avast.com/andromeda-under-the-microscope>
- Grupo APT FIN7: <https://apt.thaicert.or.th/cgi-bin/showcard.cgi?g=FIN7>
- Detención Líder Carbanak: <https://www.europol.europa.eu/newsroom/news/mastermind-behind-eur-1-billion-cyber-bank-robbery-arrested-in-spain>
- Detención grupo Carbanak: <https://www.computerweekly.com/news/252446153/Three-Carbanak-cyber-heist-gang-members-arrested>
- ESET Operación Groundbait: <https://www.welivesecurity.com/wp-content/uploads/2016/05/Operation-Groundbait.pdf>
- Qihoo 360 Poison Needles: https://blogs.360.cn/post/PoisonNeedles_CVE-2018-15982_EN
- FIN4/ Wolf Spider: <https://apt.thaicert.or.th/cgi-bin/showcard.cgi?g=FIN4%2C%20Wolf%20Spider>
- Análisis EFF sobre Appin: <https://www.eff.org/files/2016/08/03/i-got-a-letter-from-the-government.pdf>
- Disección Careto: <https://ciberseguridad.blog/apt-caretomalware-careto-un-apt-con-origen-en-espana/>